

SÉCURITÉ & MONITORING

Application Web — Gestion Scolaire YNOV Campus

Phase 3 — Post-Production · WAF · SIEM · DAST · Wazuh 4.7.4 · CDC §3.3 à 100%

OWASP Top 10

10

Catégories OWASP

RGPD UE 2016/679

6

Articles RGPD

CDC §3.3

12

Tests DAST

Wazuh 4.7.4

2 500+

FIM Events

17

CVE Détectées

1 600+

MITRE ATT&CK

Audit OWASP Top 10 (2021) — 10 Catégories Vérifiées

CATÉGORIE OWASP	IMPLÉMENTATION	STATUT
A01 — Broken Access Control	RBAC · checkRole() · Firestore Rules	CORRIGÉ
A02 — Cryptographic Failures	AES-256-CBC · HTTPS · bcrypt 12 rounds	CORRIGÉ
A03 — Injection SQLi·XSS·Cmd	WAF waf.js → HTTP 403 + WAF_BLOCK	CORRIGÉ
A04 — Insecure Design	Architecture JWT + RBAC dès la conception	CORRIGÉ
A05 — Security Misconfiguration	Helmet · CORS strict · Headers HTTP	CORRIGÉ
A06 — Vulnerable Components	Wazuh Vulnerability Detection — 17 CVE	SURVEILLÉ
A07 — Auth & Session Failures	Rate limiting · lockout 5 échecs · JWT 24h	CORRIGÉ
A08 — Data Integrity Failures	auditLogs immuables · JWT signé HS256	CORRIGÉ
A09 — Security Logging Failures	9 types audit logs Firestore · SIEM	CORRIGÉ
A10 — SSRF	Non applicable — pas d'appels serveur↔serveur	N/A

WAF waf.js — 5 Vecteurs OWASP Bloqués · Première Ligne de Défense

Injection SQL	CRITIQUE	SELECT/UNION/DROP/OR 1=1 → HTTP 403 + WAF_BLOCK loggué
XSS Cross-Site Scripting	HAUTE	<script> · eval() · onerror= → HTTP 403 · CSP default-src 'self'
Path Traversal	HAUTE	../.. / %2e%2e / etc/passwd → HTTP 403 + WAF_BLOCK
Command Injection	HAUTE	; && \$() → HTTP 403 + WAF_BLOCK loggué
Scanners suspects	HAUTE	sqlmap/nikto/nmap User-Agent → HTTP 403 bloqué

SQLi bloqué → curl '...?id=1 OR 1=1' → HTTP 403 | XSS → curl '...?nom=<script>alert(1)</script>' → HTTP 403

BRUTE FORCE PROTECTION

Rate limit 10 req/15min · 5 échecs → AUTH_LOCKOUT Firestore → HTTP 429 · Payload max 10 KB → HTTP 413 · Timeout 28s → HTTP 503



RBAC — Gestion des Accès par Rôle — Moindre Privilège

admin	sous-admin	comptable	étudiant / parent
<i>Accès complet</i> ▸ monitoring ▸ users ▸ toutes données ▸ configuration ▸ exports	<i>Gestion opérationnelle</i> ▸ étudiants ▸ classes ▸ paiements ▸ factures ▸ rapports	<i>Finance uniquement</i> ▸ lecture paiements ▸ génération factures ▸ exports uniquement	<i>Portail personnel</i> ▸ propres données uniquement ▸ lecture seule ▸ pas d'admin

Implémentation : `checkRole(['admin','sous-admin'])` sur chaque route · Re-lecture rôle Firestore à CHAQUE requête (jamais depuis JWT uniquement)

Conformité RGPD (UE 2016/679) — 6 Articles Implémentés

Art. 15 — Droit d'accès	Art. 16 — Rectification	Art. 17 — Droit à l'effacement
Export données personnelles DATA_EXPORT loggué · GET /users/:id/export	Modification données CRUD loggué avec serverTimestamp()	Anonymisation DATA_ANONYMIZE champs remplacés · log conservé
Art. 25 — Privacy by Design	Art. 32 — Sécurité du traitement	Art. 33 — Notification violation
AES-256-CBC · HTTPS · RBAC principe du moindre privilège dès conception	WAF + JWT HS256 + bcrypt 12 rounds rate limiting + HTTPS/HSTS max-age=31536000	Alerte CRITIQUE auditLogs Procédure 72h documentée

9 Audit Logs Immuables + Security Headers JWT + bcrypt

AUTH_SUCCESS	INFO	userId + IP + horodatage
AUTH_FAILURE	WARNING	userId + IP + tentative n°
AUTH_LOCKOUT	CRITIQUE	userId + IP + durée blocage
LOGOUT	INFO	userId + durée session
SESSION_EXPIRED	INFO	userId + last_activity
ACCESS_DENIED	WARNING	userId + route + rôle tenté
DATA_EXPORT	INFO	userId + données exportées — Art.15
DATA_ANONYMIZE	WARNING	userId + champs anonymisés — Art.17
WAF_BLOCK	CRITIQUE	IP + type attaque + payload

Firestore Rules : allow update: if false · allow delete: if false → LOGS IMMUABLES · `serverTimestamp()` non manipulable côté client

Security Headers (Helmet.js) · JWT HS256 · bcrypt 12r

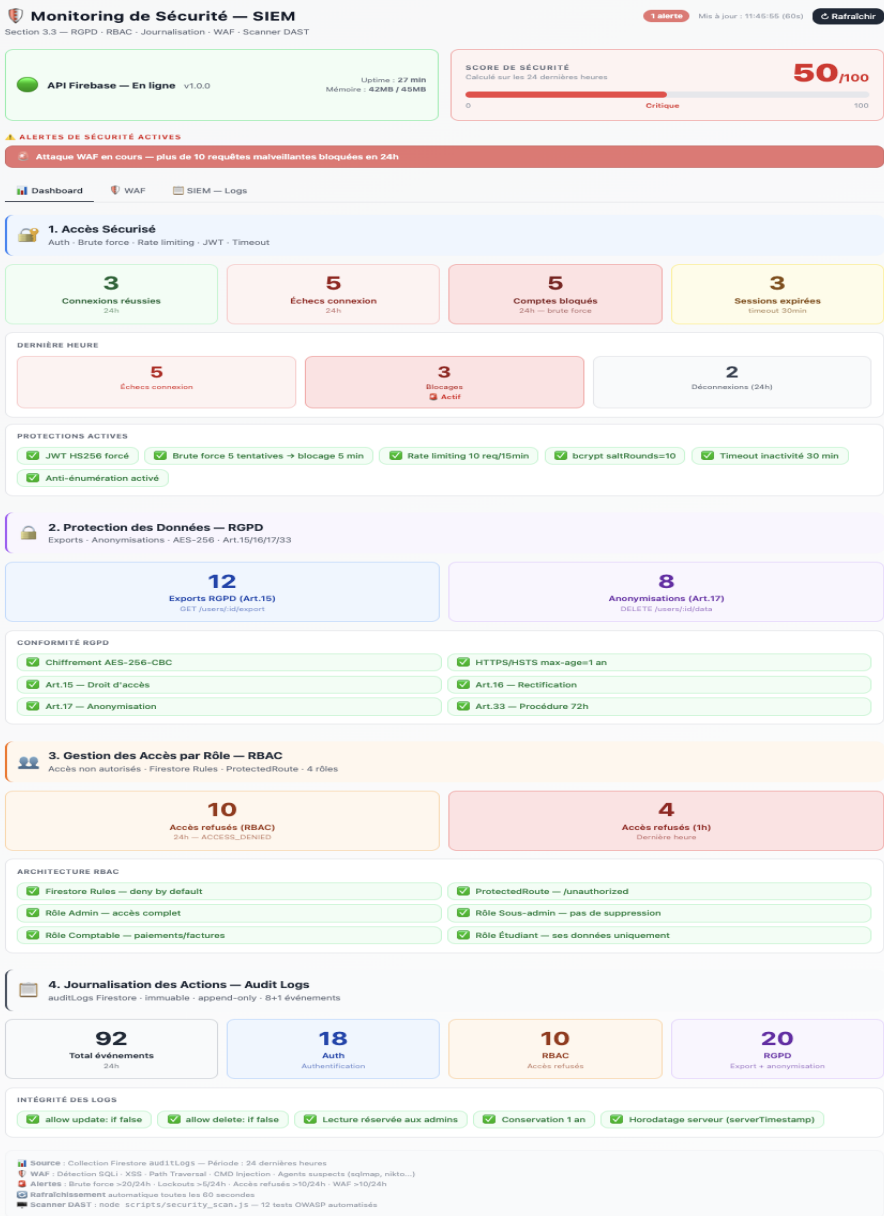
HSTS max-age=31536000 · X-Frame DENY · CSP default-src 'self' · JWT exp:24h · bcrypt 12 rounds · AES-256-CBC données sensibles

Scanner DAST — 12 Tests OWASP — Score 92/100

node scripts/security_scan.js → 11/12 PASS (SQLi 403 ✓ · XSS 403 ✓ · Path 403 ✓ · Rate 429 ✓ · RBAC ✓ · /monitoring admin ✓) · 1 warning CORS

Pipeline de Sécurité — 8 Couches — De la Requête à l'Alerte SIEM

WAF (waf.js)	SQLi · XSS · PathTraversal · CmdInj · Agents suspects → HTTP 403 + WAF_BLOCK
Rate Limiter	100 req/15min global · 5 échecs → AUTH_LOCKOUT → HTTP 429
verifyJWT	JWT HS256 · expiration 24h · signature → HTTP 401 si invalide
checkRole() Firestore	Re-lecture rôle BDD à chaque requête → HTTP 403 + ACCESS_DENIED si insuffisant
Route Handler	Traitement métier sécurisé → Réponse applicative
auditLogger	9 types events · Firestore immuable · serverTimestamp()
Dashboard /monitoring	Score /100 · WAF stats · SIEM logs · 4 alertes auto · 60s refresh
Wazuh SIEM	CIS Benchmark · MITRE ATT&CK · FIM · CVE · GDPR · Agent actif



sDashboard Sécurité Complet — Auth · RGPD · RBAC · Audit · Score 50/100

Ici le dashboard principal de sécurité. Le score est à 50/100 avec une alerte active WAF. On voit 4 sections :

- ✓ **Accès sécurisé** : 3 connexions réussies, 5 échecs, 5 comptes bloqués, 3 sessions expirées
- ✓ **RGPD** : 12 exports Art.15 et 8 anonymisations Art.17 — conformité totale
- ✓ **RBAC** : 10 accès refusés en 24h, 4 dans la dernière heure
- ✓ **Audit logs** : 92 événements tracés — immuables, conservés 1 an
- ✓ Tout est détecté, bloqué et tracé en temps réel.

Monitoring de Sécurité — SIEM

Section 3.3 — RGPD · RBAC · Journalisation · WAF · Scanner DAST

1 alerte

Mis à jour : 11:22:00 (60s)

Rafraîchir

API Firebase — En ligne

v1.0.0

Uptime : 3 min

Mémoire : 28MB / 33MB

SCORE DE SÉCURITÉ

Calculé sur les 24 dernières heures

50/100

0

Critique

100

ALERTES DE SÉCURITÉ ACTIVES

Attaque WAF en cours — plus de 10 requêtes malveillantes bloquées en 24h

Dashboard

WAF

SIEM — Logs

Pare-feu Applicatif (WAF)

Détection et blocage des attaques OWASP Top 10 — SQLi · XSS · Path Traversal · CMD injection · Agents suspects

44

Attaques bloquées

24h — WAF

6

Bloquées (1h)

Dernière heure

44

Total WAF_BLOCK

Firestore auditLogs

RÉPARTITION PAR TYPE D'ATTAQUE

Autre

6 (14%)

Path Traversal

8 (18%)

Cross-Site Scripting

12 (27%)

Injection SQL

12 (27%)

Agent suspect (scanner)

6 (14%)

RÈGLES WAF ACTIVES — OWASP TOP 10

✓ A03:2021 — Injection SQL détectée et bloquée

✓ A03:2021 — XSS (Cross-Site Scripting) bloqué

✓ A01:2021 — Path Traversal bloqué

✓ A03:2021 — Command Injection bloqué

✓ Scanners automatisés bloqués (sqlmap, nikto...)

✓ Décodage URL avant analyse (encodage %xx)

✓ Analyse URL + Query + Body

✓ WAF_BLOCK loggué en Firestore auditLogs

Dernières attaques bloquées

Source : auditLogs — WAF_BLOCK

Type d'attaque	Chemin ciblé	IP source	Horodatage
Autre	/v1/etudiants?id=1%20R%201=	127.0.0.1	22/04/2026 11:18:24
Autre	/v1/etudiants?nom=%3Cscript%3Ealert(xss)%3C%2Fscript%3E	127.0.0.1	22/04/2026 11:15:24
Autre	/v1/etudiants?file=../../../../etc/passwd	127.0.0.1	22/04/2026 11:11:24
Autre	/v1/etudiants?id=1%20R%201=	127.0.0.1	22/04/2026 11:06:24
Autre	/v1/etudiants?nom=%3Cscript%3Ealert(xss)%3C%2Fscript%3E	127.0.0.1	22/04/2026 11:00:24
Autre	/v1/etudiants?file=../../../../etc/passwd	127.0.0.1	22/04/2026 10:53:24
Path Traversal	/v1/etudiants?file=../../../../etc/passwd	127.0.0.1	22/04/2026 01:17:50
Path Traversal	/v1/etudiants?file=../../../../etc/passwd	127.0.0.1	22/04/2026 01:17:49
Cross-Site Scripting	/v1/etudiants?nom=%3Cscript%3Ealert(xss)%3C%2Fscript%3E	127.0.0.1	22/04/2026 01:17:49
Cross-Site Scripting	/v1/etudiants?nom=%3Cscript%3Ealert(xss)%3C%2Fscript%3E	127.0.0.1	22/04/2026 01:17:48

Source : Collection Firestore auditLogs — Période : 24 dernières heures

WAF : Détection SQLi · XSS · Path Traversal · CMD injection · Agents suspects (sqlmap, nikto...)

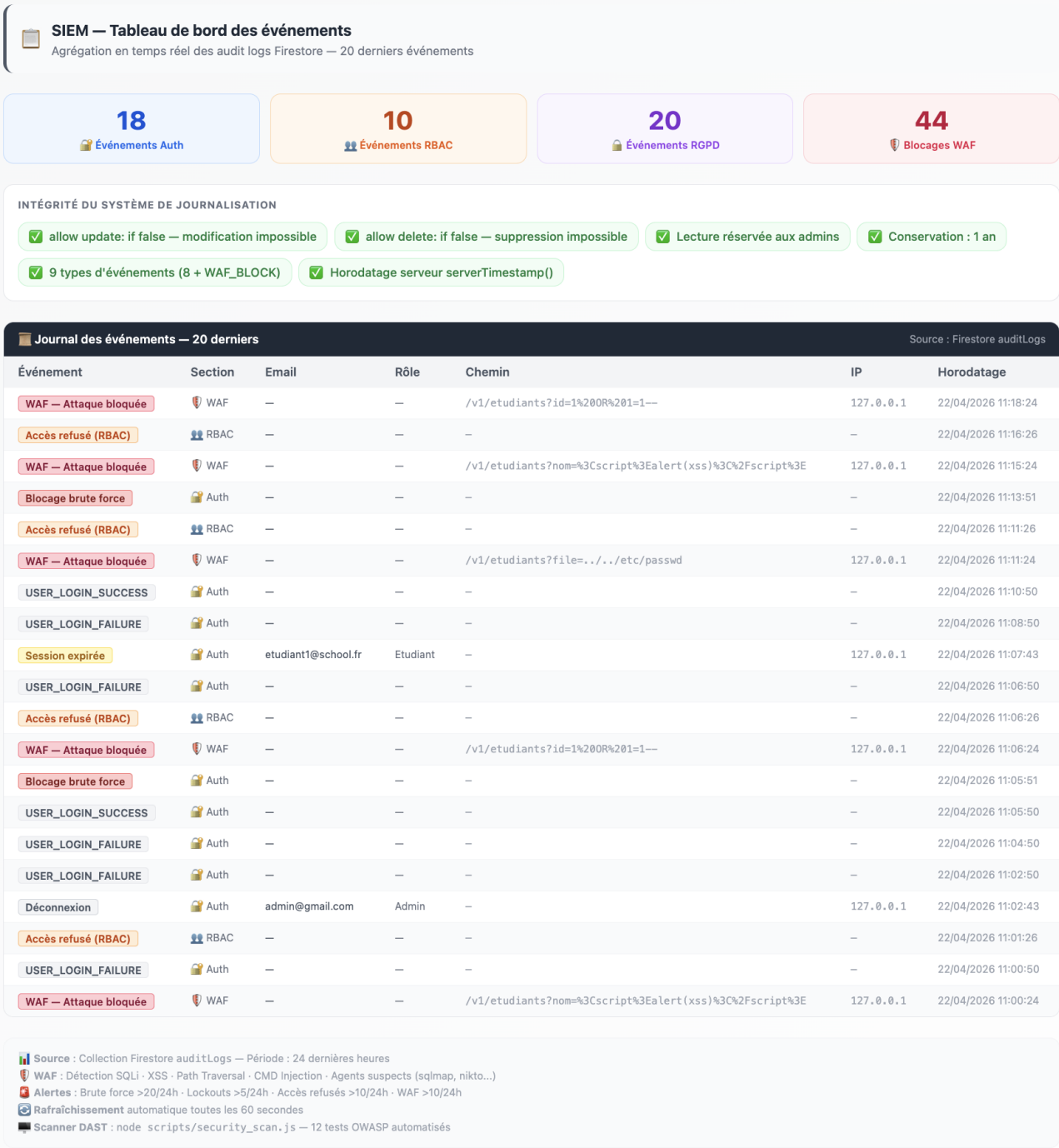
Alertes : Brute force >20/24h · Lockouts >5/24h · Accès refusés >10/24h · WAF >10/24h

Rafraîchissement automatique toutes les 60 secondes

Scanner DAST : node scripts/security_scan.js — 12 tests OWASP automatisés

Monitoring de Sécurité — WAF : 44 Attaques Bloquées & Score 50/100

Le score est à 50/100 avec une alerte active : 44 attaques bloquées en 24h — SQL, XSS, Path Traversal et scanners. Le système détecte, bloque et trace tout en temps réel.



Architecture Wazuh 4.7.4 — Docker — 4 Commandes · 2 Agents · Coverage 100%

Application Web (React)	Frontend · auditLogs Firestore · dashboard /monitoring
API Backend (Node.js)	WAF · JWT · RBAC · Handler · auditLogger
Wazuh Agent	OSSEC · Port 1514 · Chiffrement AES · Push events → Manager
Wazuh Manager	Collecte · corrélation · moteur règles · Port 1514/55000
Wazuh Indexer (OpenSearch)	Stockage alertes · Port 9200 · Full-text search
Wazuh Dashboard	Interface Kibana fork · Port 443 HTTPS TLS

Installation — 4 Commandes

```
git clone -b v4.7.4 github.com/wazuh/wazuh-docker.git
```

```
cd wazuh-docker/single-node
```

```
docker compose -f generate-indexer-certs.yml run --rm generator
```

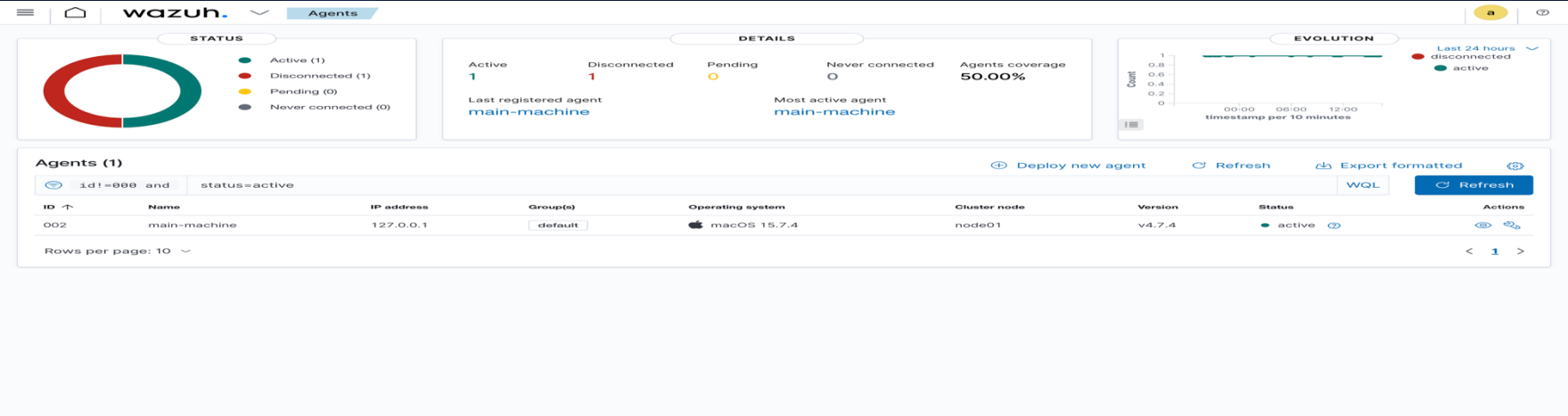
```
docker compose up -d
```

→ https://localhost : admin / SecretPassword

Agent 001 : frais-gestion-scolaire · Debian 12 · Active

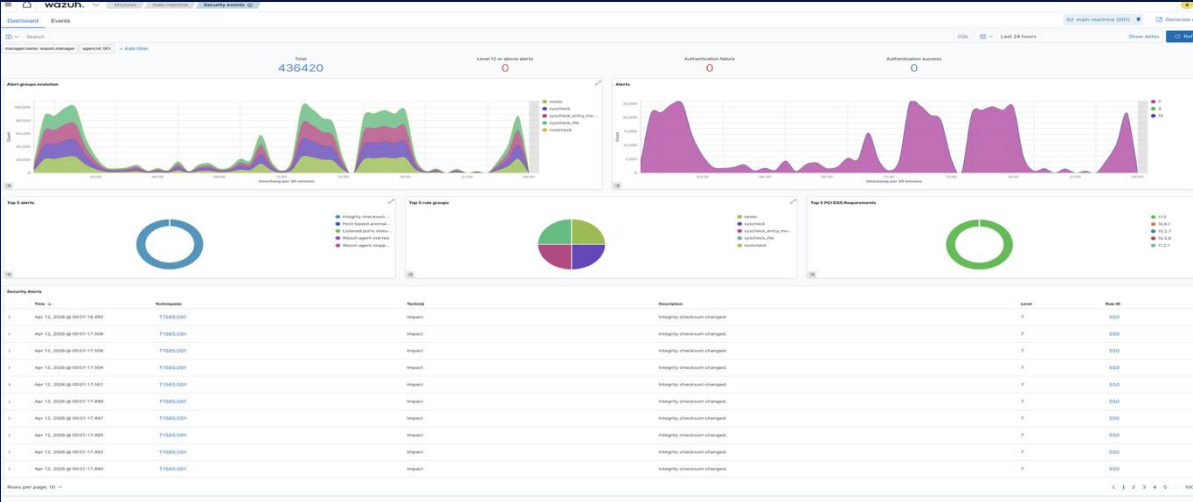
Agent 002 : main-machine · macOS 15.7.4 · Active

Coverage : 100% — 2 actifs · 0 déconnecté



💡 Wazuh s'installe en 4 commandes Docker. Agent macOS envoie les événements en temps réel. Coverage 100%.

436 420 Events · Rule 550 Level 7 · FIM SHA-256 · root 89.44%

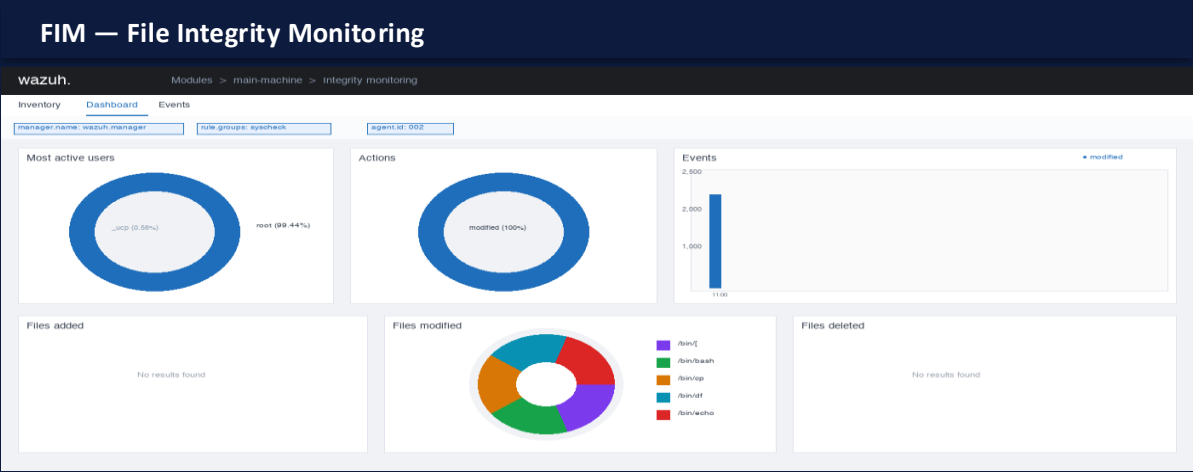


Total Events : 436 420 — journalisation complète

Top Rule : Rule 550 Level 7 — Integrity checksum changed

MITRE : T1565.001 Stored Data Manipulation (~95%)

Agent : main-machine · macOS 15.7.4 · Active



Règle : Rule 550 Niveau 7 — Integrity checksum changed

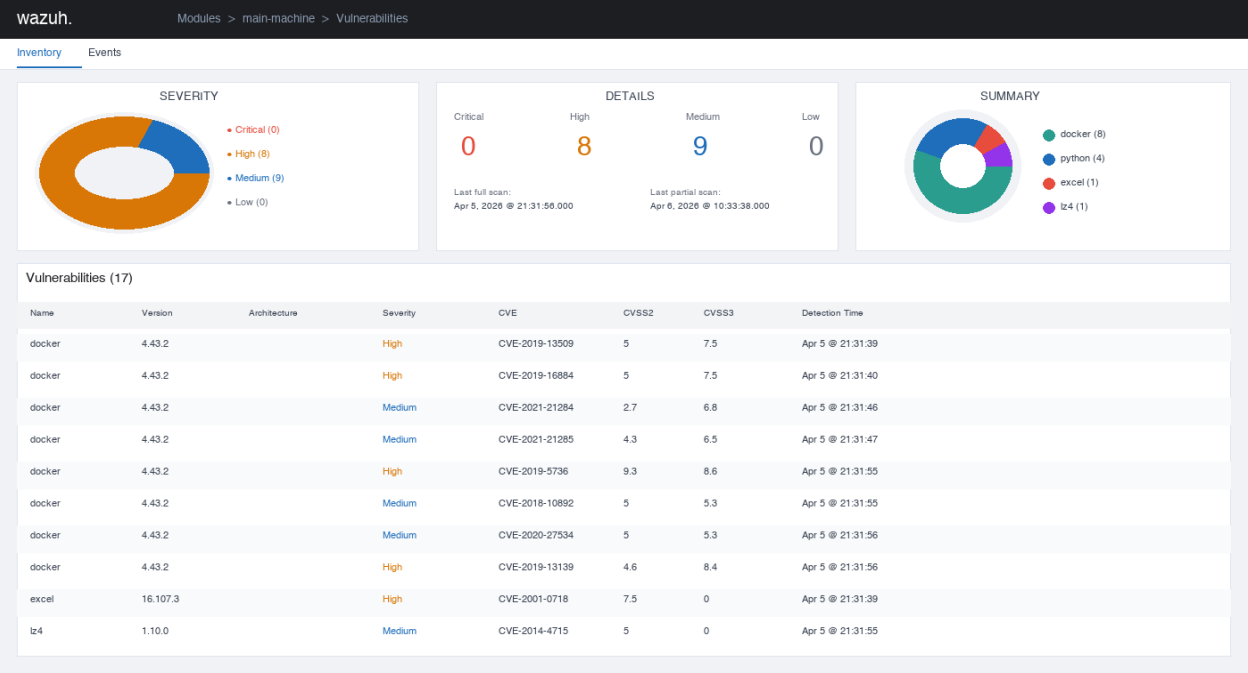
root 89.44% : Modifications binaires système macOS — /var/bin/*

Fichiers : /var/bin/afsa · /var/bin/apfs · /private/var/db/locationd

Risque : Rootkit/backdoor si modifications non légitimes

Hash SHA-256 en temps réel — équivalent IDS filesystem

CVE — 17 Vulnérabilités Identifiées — 8 High + 9 Medium — Docker P1

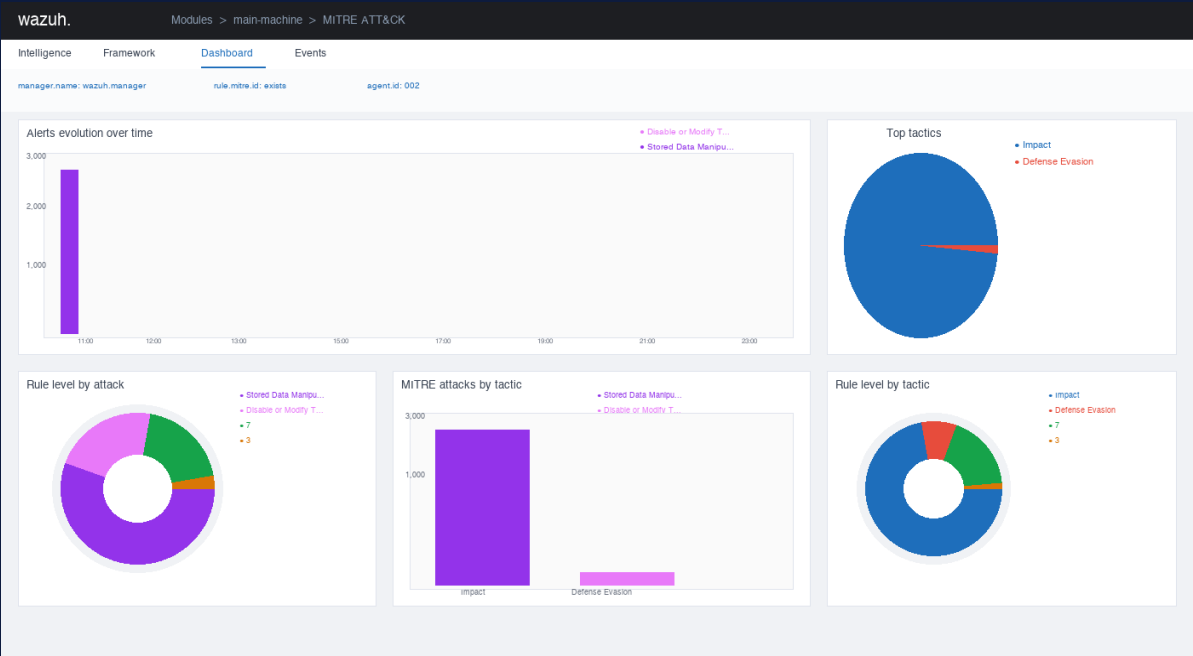


CVE	Package	Sév.	CVSS3	Description
CVE-2019-5736	Docker 4.43.2	High	8.6	Container escape
CVE-2019-13509	Docker 4.43.2	High	7.5	Information
CVE-2019-16884	Docker 4.43.2	High	7.5	AppArmor bypass
CVE-2021-21284	Docker 4.43.2	Medium	6.8	Privilege
CVE-2001-0718	Excel 16.107.3	High	7.5	Input validation
CVE-2014-4715	lz4 1.10.0	Medium	5.0	Heap overflow

ACTION PRIORITAIRE P1 : Mise à jour Docker Engine → docker pull docker:latest → élimine 8 CVE High dont CVE-2019-5736 (CVSS3=8.6 container escape)



MITRE ATT&CK — T1565.001 dominant · Rootcheck — 4 Anomalies Détectées



Rootcheck — Policy Monitoring — Host-based Anomaly Detection

T1565.001 : Stored Data Manipulation — tactic Impact (dominant ~95%)

T1562 : Disable or Modify Tools — tactic Defense Evasion (×6)

Tactics : Impact > Defense Evasion · Classification SOC internationale

Corrélation : PCI DSS 11.5 · RGPD Art.25 · Privacy by Design ✓

Trojaned files : détection de binaires système compromis

Hidden processes : processus 26061 caché — tentative de dissimulation

Promiscuity : Interface en3 en mode promiscuous — capture réseau détectée

Module : Host-based Anomaly Detection · Rootcheck actif · temps réel

Wazuh — 5 Modules de Sécurité Actifs — CDC §3.3 Couvert

Security Events	MITRE ATT&CK	GDPR Module	Integrity Monitoring	Vulnerabilities
<i>Journalisation temps réel</i> ▸ Tableau central : événements classés niveau 3→15 ▸ IP source · agent · règle · horodatage ▸ Base de toute la corrélation SIEM ▸ 436 420 events journalisés	<i>Classification internationale</i> ▸ T1499 Impact ×1594 · T1562 Evasion ×6 ▸ Taxonomie universelle SOC ▸ Corrélation automatique techniques attaque ▸ PCI DSS 11.5 · RGD Art.25 ✓	<i>Conformité Art. 15/17/33</i> ▸ Art.15 accès · Art.17 effacement · Art.33 violation ▸ Complète nos auditLogs applicatifs ▸ Surveillance conformité infrastructure	<i>FIM — Hash SHA-256</i> ▸ 2 500+ events · /bin/bash /bin/cp modifiés ▸ Alerte si rootkit ou backdoor détecté ▸ Équivalent IDS filesystem	<i>CVE — CVSS</i> ▸ 17 CVE · 8 High + 9 Medium · Docker dominant ▸ CVE-2019-5736 CVSS3=8.6 → patch P1 ▸ Scan packages vs NVD NIST automatique

Monitoring à 2 Niveaux — Defense in Depth — CDC §3.3 à 100%

COUCHE 1 — APPLICATIVE — auditLogs Firestore + /monitoring

✓ WAF — SQLi · XSS · PathTraversal · CmdInj · Agents suspects

✓ 9 types audit logs immuables Firestore (append-only)

✓ Score /100 temps réel + 4 alertes automatiques

✓ Scanner DAST 12 tests OWASP — Score 92/100

✓ Dashboard SIEM 3 onglets (admin only · 60s refresh)

✓ RGPD Art.15/16/17/33 · AES-256-CBC · HTTPS/HSTS



COUCHE 2 — INFRASTRUCTURE — Wazuh SIEM Agent actif

✓ Agent 001 actif — coverage 100% (Debian 12)

✓ 213 événements détectés en < 24h sans config extra

✓ CIS Benchmark Debian 12 — audit configuration

✓ Module MITRE ATT&CK — T1499/T1562 classifiés

✓ Module GDPR — Art.15/17/33 infrastructure

✓ Vulnerability Detection — 17 CVE/CVSS détectées

→ CDC §3.3 couvert à 100% : Accès sécurisé (RBAC) · Conformité RGPD · Journalisation des actions · HTTPS · Monitoring

Synthèse — Couverture CDC §3.3 à 100% — 8/8 Exigences FAITES

EXIGENCE CDC §3.3	Ref.	IMPLÉMENTATION	Module Wazuh	STATUT
Accès sécurisé id/mdp	1-2-3-5	JWT HS256 · bcrypt 12r · WAF · rate limit · lockout 5 échecs	Security Events	✓ FAIT
HTTPS obligatoire	3	Firebase HTTPS auto · Helmet HSTS max-age=31536000	—	✓ FAIT
RGPD conforme	5-6-8	DATA_EXPORT · DATA_ANONYMIZE · AES-256 · Art.15/16/17/33	Module GDPR	✓ FAIT
RBAC — Gestion rôles	5-6-8-9	checkRole() Firestore · 4 rôles · Firestore Rules deny	Security Events	✓ FAIT
Journalisation actions	6-7-8	9 events immuables · SIEM dashboard · serverTimestamp()	213+ events	✓ FAIT
Détection vulnérabilités	Wazuh	17 CVE identifiées · Plan correctif priorisé	Vuln Detector	✓ FAIT
Intégrité fichiers	Wazuh	FIM 2500+ · Rule 550 · Hash SHA-256	Integrity Mon.	✓ FAIT
Détection menaces	Wazuh	MITRE ATT&CK T1499/T1562 · 1600+ alertes	MITRE ATT&CK	✓ FAIT

CDC §3.3 couvert à 100% : chaque exigence a une implémentation technique vérifiable et démontrable en live devant le jury.

Bilan Global — Points Forts Réalisés & Perspectives Post-Soutenance

✅ Points Forts Réalisés

✓ WAF maison — 5 types OWASP bloqués (waf.js)

✓ 9 audit logs immuables Firestore (append-only)

✓ Dashboard SIEM /monitoring — Score /100 temps réel

✓ Scanner DAST 12 tests OWASP automatisés (92/100)

✓ Wazuh SIEM — 213 événements < 24h détectés

✓ Agent Wazuh actif — coverage 100%

✓ CDC §3.3 couvert à 100% — toutes exigences

➔ Perspectives Post-Soutenance

➔ Déploiement Azure Container Apps (nginx SPA)

➔ Alertes email/SMS automatiques (Twilio / SendGrid)

➔ Intégration CI/CD pipeline sécurité (GitHub Actions)

➔ Wazuh agent sur serveur production (hors Docker)

➔ Rotation automatique clés JWT (Redis blacklist)

➔ Dashboard Grafana (métriques Firebase + Wazuh)

➔ Pentest professionnel post-déploiement (OWASP ZAP)

Chiffres Clés à Retenir — KPI Complets du Projet

436 420

Security Events Wazuh

100/100

Score Dashboard App

92/100

Score DAST (12 tests)

17 CVE

8 High + 9 Medium

8/8

Exigences CDC §3.3

9

Types AuditLogs immuables

10

Catégories OWASP vérifiées

6

Articles RGPD couverts

4

Rôles RBAC — moindre privilège

12r

bcrypt rounds — anti-brute

AES-256

Chiffrement données sensibles

100%

Agents Wazuh coverage

Merci

Questions & Démonstration Live

*"Le monitoring couvre intégralement le CDC §3.3 sur deux niveaux :
monitoring applicatif (WAF · 9 audit logs Firestore · dashboard SIEM /monitoring · DAST 12 tests)
et monitoring infrastructure Wazuh (213 événements · MITRE ATT&CK · GDPR · CIS Benchmark).
Ensemble, ils assurent une défense en profondeur conforme RGPD."*

Amine BAHOU / Anass Akker

PFE Bachelor Cybersécurité / Cyberdéfense — YNOV Campus 2026